

정보보안 이론과 실제

3판

암호, 접근제어, 네트워크 보안, 소프트웨어

[강의교안 이용 안내]

- 본 강의교안의 저작권은 한빛아카데미(주)에 있습니다.
- 이 자료를 무단으로 전제하거나 배포할 경우 저작권법 136조에 의거하여 처벌을 받을 수 있습니다.



정보보안 이론과 실제

3판

암호, 접근제어, 네트워크 보안, 소프트웨어

Chapter 07 인가

차례

7.1 개요

7.2 인가의 역사

7.3 접근제어 행렬

7.4 다단계 보안 모델

7.5 은닉 채널

7.6 추론 제어

7.7 캡차

7.8 요약

7.1 개요

■ 인가(authorization)

- 인증된 사용자의 행동을 제한하는 것으로 접근제어의 일부
- 이미 인증된 사람이 할 수 있는 것에 제한을 두는 것

■ 보안 제품을 인증하는 것

- '오렌지북'
- '공통 평가 기준'

■ 램슨(Lampson)의 접근제어 행렬

- 접근제어 목록, 권한 목록, 대리 혼돈 문제

■ 다단계 보안, 은닉 채널, 추론 제어, 캡차

7.2 인가의 역사

■ 오렌지북

- 신뢰할 수 있는 컴퓨팅 시스템 평가 기준(TCSEC)
 - 1983년에 출판
- 국가정보기관의 후원으로 시리즈로 개발
- 목적
 - '자동 데이터 처리 시스템 제품'의 보안 수준을 평가하는 기준을 제공하는 것
- 목표
 - 기밀 또는 민감한 정보를 안전하게 처리하기 위한 컴퓨터 시스템의 신뢰 정도를 평가하는 기준을 사용자에게 제공하기
 - 민감한 응용 프로그램에 대한 신뢰 요건을 만족시키려면 새로운 제품을 만들 때 구축해야 하는 것과 관련된 지침을 제조사에게 제공하기
 - 보안 요구사항을 명시하기 위한 근거를 제공하기

7.2 인가의 역사



■ 오렌지북의 보안 등급

- 구분 D: 최소의 보호
- 구분 C: 재량적 보호
 - 클래스 C1: 자유재량적 보안 보호
 - 클래스 C2: 통제된 접근 보호
- 구분 B: 필수적 보호
 - 클래스 B1: 라벨이 달린 보안 보호
 - 클래스 B2: 구조화된 보호
 - 클래스 B3: 보안 영역
- 구분 A: 검증된 보호

7.2 인가의 역사

LO7

■ 공통 평가 기준

- 1990년대 오렌지북은 공통 평가 기준[24]이라는 이름으로 공식적으로 대체됨(보안 제품을 인증하는 데 사용되는 국제적인 기준이 됨)
- 오렌지북의 현대 버전
- 공통 평가 기준 인증은 1에서 7이라는 숫자를 가진 평가 보증 등급(EAL)을 만듦
 - EAL1부터 EAL7 중에서 더 높은 숫자로 갈수록 더 나은 등급
 - 실제로 EAL4를 가장 많이 추구하는데 이는 비교적 성취하기 쉽고 대부분의 경우에서 정부에게 제품을 팔기 위한 최소한의 수준이기 때문
- 누가 공통 평가 기준을 평가하는 보안 '전문가'인가?
 - 미국에서는 정부에서 승인된 공통 평가 기준 시험 실험실에서 일함
 - 승인 받은 기관은 NIST

7.3 접근제어 행렬

- 인가에 대한 전통적인 관점은 램슨(Lampson)의 접근제어 행렬에서 시작
- 인가의 두 가지 기본 구조는 접근제어 목록(ACL)과 권한 목록(C-list)
 - 접근제어 행렬의 예시

표 7-1 접근제어 행렬

	OS	회계 프로그램	회계 데이터	보험 데이터	월급 데이터
밥	rx	rx	r	—	—
앨리스	rx	rx	r	rw	rw
샘	rwX	rwX	r	rw	rw
회계 프로그램	rx	rx	rw	rw	r

7.3 접근제어 행렬

■ 접근제어 목록과 권한 목록

■ 접근제어 행렬을 나누는 방법

① 행렬을 열로 나누어 각 열을 상응하는 객체와 함께 저장

- 객체에 대해 접근할 때마다 접근제어 행렬의 열을 확인하여 특정 연산을 허락할지 여부를 결정
- 예를 들어, [표 7-1]에서 보험 데이터에 상응하는 ACL(접근제어 목록)
(밥, --), (앨리스, rw), (샘, rw), (회계 프로그램, rw)

② 접근제어 행렬을 열로 저장하는 것

- 이때 각 열은 상응하는 주체와 함께 저장됨
- 어떤 주체가 연산을 수행하려고 할 때마다 접근제어 목록에 있는 열을 확인하여 그 연산을 허락할 것인지 결정 – 권한 목록
- [표 7-1]에서 앨리스의 권한 목록
(OS, rx), (회계 프로그램, rx), (회계 데이터, r), (보험 데이터, rw), (월급 데이터, rw)

7.3 접근제어 행렬

- 같은 정보이지만 저장하는 방법만 다르기 때문에 접근제어 목록과 권한 목록이 동등해 보일 수 있음
- 이 두 방법에는 미묘한 차이가 있음
- [그림 7-1]의 화살표가 서로 반대 방향을 향하고 있음

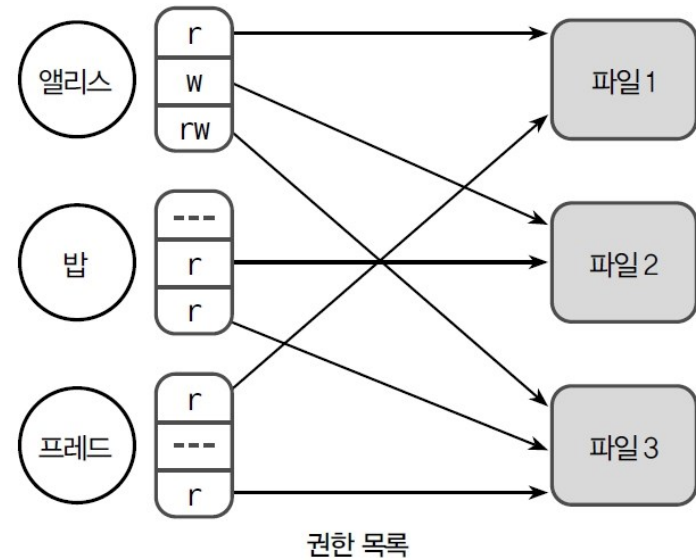
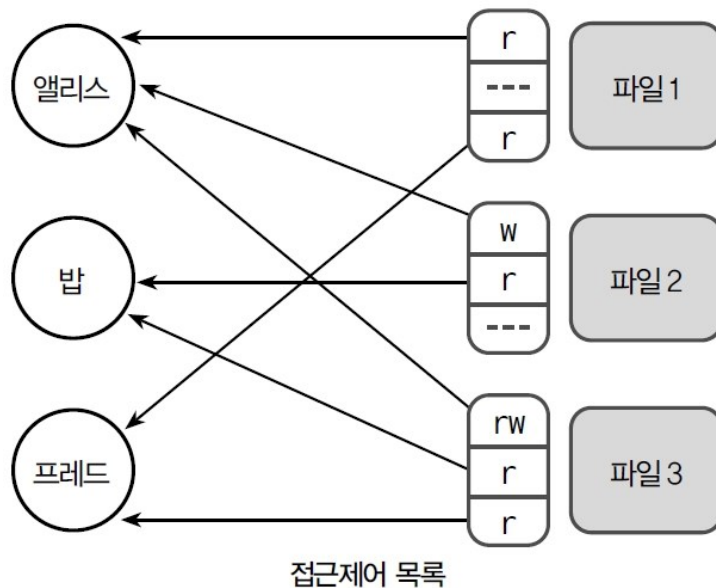


그림 7-1 접근제어 목록과 권한 목록

7.3 접근제어 행렬

대리자 혼돈

■ 대리 혼돈(confused deputy)

표 7-2 대리 혼돈 예시의 접근제어 행렬

	컴파일러	청구서
앨리스	x	—
컴파일러	rx	rw

- 앨리스가 컴파일러를 실행시키고 '청구서'를 디버그 파일 이름으로 제공한다고 가정



그림 7-2 대리 혼돈

7.3 접근제어 행렬

- 접근제어 목록을 사용할 경우 대리 혼돈 문제를 피하는 것은 불가능하지는 않지만 더 어려움
- 권한 목록을 사용하면 대리인이 혼돈을 겪는 것을 방어하는 것이 상대적으로 쉬움(권한 목록은 쉽게 위임되기 때문)
- 접근제어 목록은 사용자들이 자신의 파일을 관리하고 데이터 지향적으로 방어가 이루어질 때 선호되는 방식임
- 접근제어 목록을 사용하면 특정 자원에 대한 권한을 변경하는 것이 용이해짐
- 권한 목록을 사용하면 위임(또는 하위 위임, 하위-하위 위임)이 쉬우며 사용자를 추가하거나 삭제하는 것이 더 쉬움
- 위임할 수 있는 능력 때문에 권한 목록을 사용할 때 대리 혼돈을 피하는 것이 쉬움
- 권한 목록은 실행하기에 더 복잡하며 다소 더 높은 오버헤드를 가지고 있음

7.4 다단계 보안 모델

■ 다단계 보안(MLS; Multi Level Security)

- 주체가 사용자이며 객체는 보호되어야 할 데이터
 - 취급 등급은 주체에게 적용되지만 기밀 등급은 객체에 적용
 - 미국 국방성이 4단계의 기밀 등급과 취급 등급을 구별하는 순서
극비 > 비밀 > 기밀 > 일반 평문 (7.1)
- 다단계 보안은 주체와 객체가 다른 등급에 있으면서 같은 시스템 자원을 사용할 때 필요
- 오늘날 전통적으로 기밀로 분류되는 정부 환경 외에서도 다단계 보안은 실제로 많이 사용
- 다단계 보안의 응용 프로그램으로 네트워크 방화벽이 있음

7.4 다단계 보안 모델

■ 벨-라파둘라 모델(BLP; Bell-LaPadula)

■ 목적

- 그 어떤 다단계 보안 시스템이든 만족시키는 최소한의 기밀 요구사항을 캡처하는 데 있음

■ 요약

- **단순 보안 조건** $L(O) \leq L(S)$ 일 경우에만 주체 S 는 객체 O 를 읽을 수 있다.
- ***-특성(스타 특성)** $L(S) \leq L(O)$ 일 경우에만 주체 S 가 객체 O 를 쓸 수 있다.
- '스타' 특성은 다소 덜 명확함. 이 특성은 말하자면 '극비' 정보가 '비밀' 문서에 쓰이는 것을 방지하기 위해 설계된 것
- 코헨(Cohen)은 멀웨어가 다단계 보안을 손상시키기 위해 사용될 수 있다고 말함
- 결과적으로, BLP는 '상향 읽기 금지 및 하향 쓰기 금지'로 꽤 명확하게 기술됨

7.4 다단계 보안 모델

- BLP는 '너무 쉬워서 현실적으로도 이를 적용하고 있지 않은 보안 모델은 상상하기 어렵다' – 맥린(McLean)
- BLP의 결점을 도출하기 위한 시도로 맥린은 '시스템 Z'를 정의함
- 맥린의 비판에 대해 벨과 라파둘라는 BLP를 안정 특성으로 보강함
- 벨과 라파둘라는 보안 등급 변경이 '확정된 보안 정책'을 위반하지 않는다면 보안 등급을 바꿀 수 있는 약성 안정 특성을 제공하기도 함

7.4 다단계 보안 모델

■ 비바 모델(biba's model)

- BLP는 기밀성을 다루는 데 반해 비바 모델은 무결성을 다룸
 - 비바 모델을 공식적으로 기술하기 위해 $\ell(O)$ 를 객체 O 의 무결성이라고 하고 $\ell(S)$ 를 주체 S 의 무결성이라고 하자.
- 비바 모델은 다음과 같은 두 가지로 정의
 - 쓰기 접근 규칙 $\ell(O) \leq \ell(S)$ 인 경우에만 주체 S 는 객체 O 를 쓸 수 있다.
 - 비바 모델 $\ell(S) \leq \ell(O)$ 인 경우에만 주체 S 는 객체 O 를 읽을 수 있다.
- S 가 더 낮은 무결성 수준의 객체를 보지 않도록 방지하기 때문에 비바 모델은 실제로 아주 엄격함
- 비바 모델을 다음과 같이 대체하는 것이 가능
- 저수위 원칙 주체 S 가 객체 O 를 읽으면 $\ell(S) = \min(\ell(S), \ell(O))$ 이다.

7.4 다단계 보안 모델

■ BLP와 비바 모델의 차이점

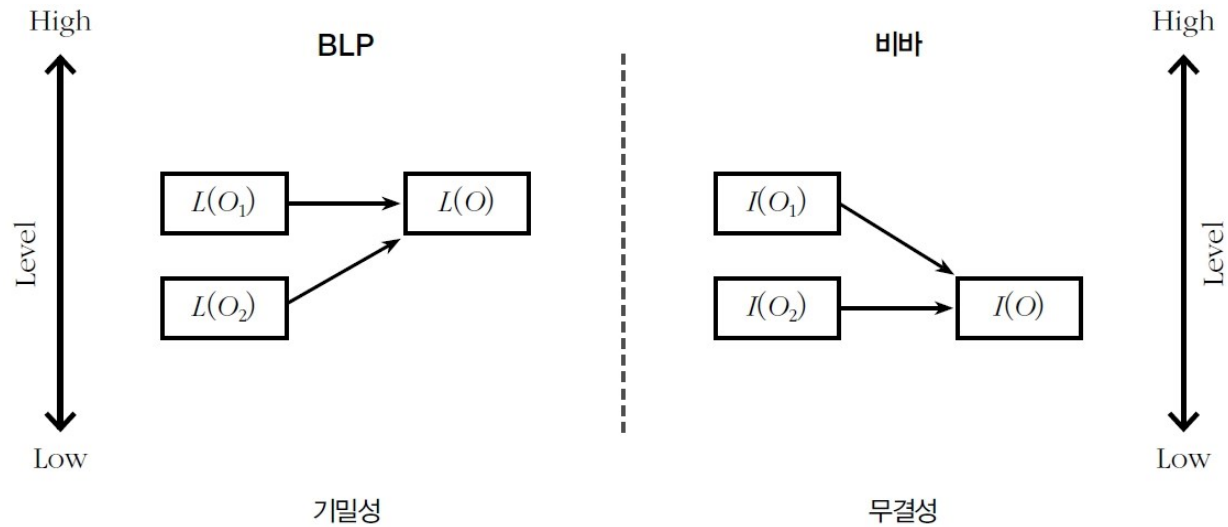


그림 7-3 BLP vs. 비바

7.4 다단계 보안 모델

■ 구획

- 일반적으로 보안 등급의 간단한 계층적 구조는 대부분의 상황을 다루기에는 유연하지 못함
- 실제적으로는 보안 등급에 '걸쳐서' 정보 흐름을 더 제한하도록 구획(compartment)을 사용할 필요가 있음
- 보안 등급과 관련된 구획을 표현하기 위해 다음과 같은 표기법을 사용
보안 등급 {구획명}
- 예: 극비 등급 내에 '고양이'와 '개' 구획이 있음
극비{고양이}, 극비{개}, 극비{고양이,개}
- 구획은 보안 등급에 따른 정보 흐름을 제한하는 효과를 냄
- 구획은 지식 한정 원칙을 실현하는 일을 담당

7.4 다단계 보안 모델

- 왜 새로운 보안 등급을 만드는 대신에 구획을 만드는가?

- 다음의 두 개의 조건이 불가능할 경우임

극비{고양이} ≤ 극비{개}

극비{고양이} ≥ 극비{개}

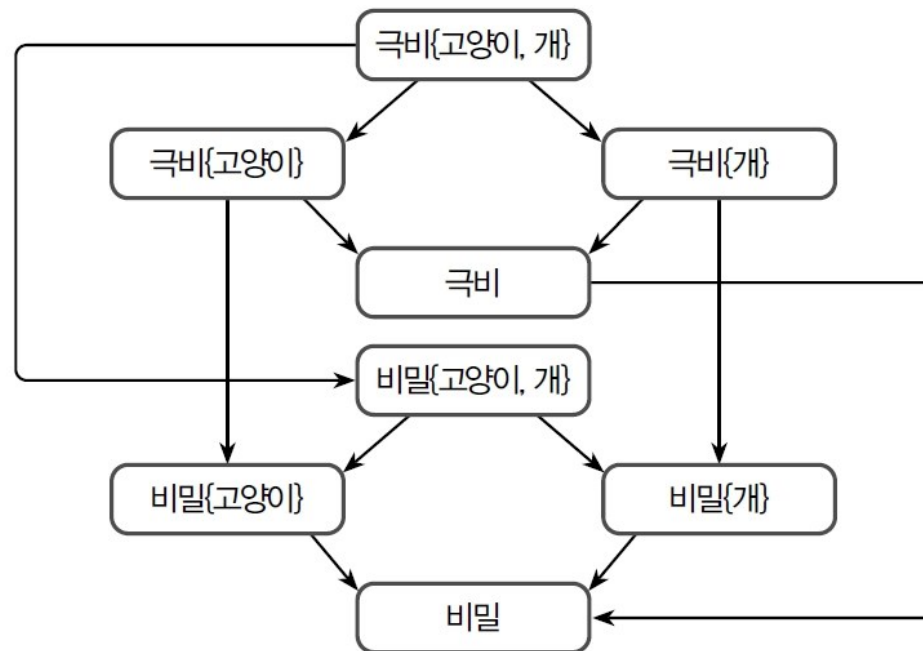


그림 7-4 구획 예시

7.5 은닉 채널

■ 은닉 채널(covert channel)

- 시스템의 설계자가 의도하지 않은 통신 경로
 - 네트워크로 연결된 시스템에서 특히 많이 발생
 - 사실상 제거하기 불가능하므로 주안점을 두고자 하는 것은 그런 통로의 용량을 제한하는 것에 있음
 - 은닉 채널은 정보가 흘러가는 또 다른 길을 제공
 - 은닉 채널은 어디에든 있음. 특히, 네트워크는 은닉 채널의 풍부한 자원
 - 몇몇 해킹 도구는 네트워크상에서의 은닉 채널을 악용

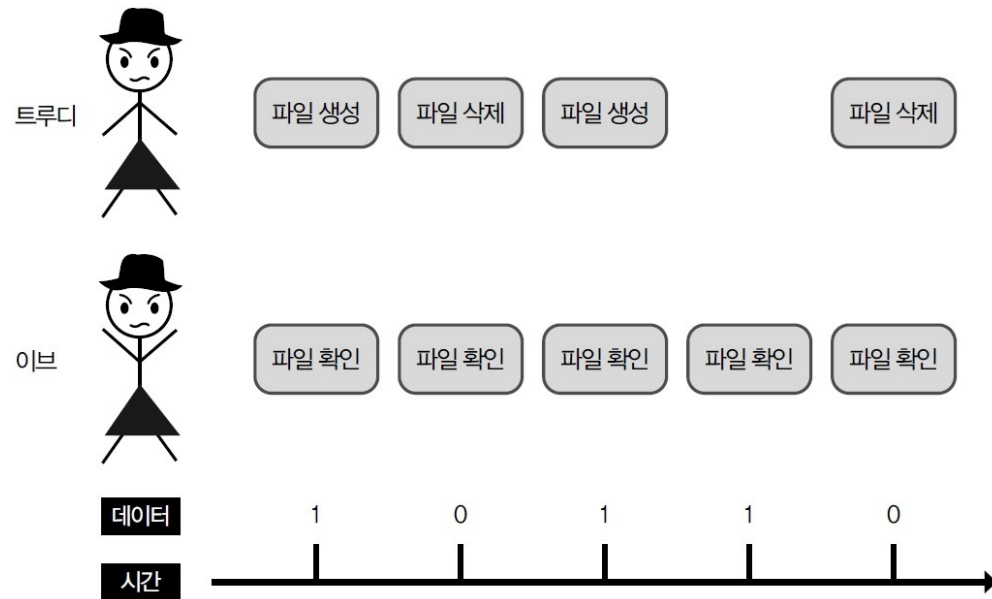


그림 7-5 은닉 채널 예시

7.5 은닉 채널

- 은닉 채널이 존재하기 위해서는 세 가지가 필요
 - 송신자와 수신자가 공유된 자원에 대한 접근 권한을 가지고 있어야 함
 - 송신자는 수신자가 관찰할 수 있는 공유된 자원의 어떤 특성들을 변경할 수 있어야 함
 - 송신자와 수신자는 통신을 동기화할 수 있어야 함
- 초당 한 비트로 제한하는 것이 은닉 채널이 생성하는 피해를 예방하기에 충분할까?
 - 극비 파일이 100MB 크기라고 가정
 - 이 파일의 평문 버전이 극비 파일 시스템에 저장되어 있으며 이 파일의 암호화된 버전, 예를 들어 256비트 키를 사용하는 AES로 암호화된 버전이 평문 위치에 저장되어 있다고 가정
 - 미국방부 가이드라인을 따라 이 시스템의 은닉 채널 용량을 초당 1비트로 줄여냈다고 하면, 은닉 채널을 통해 100MB 극비 문서 전체를 누출시키 데는 25년보다 더 많은 시간이 걸릴 것
 - 하지만 같은 은닉 채널을 통해 256비트 AES 키를 누출시키는 데는 5분도 걸리지 않음

7.5 은닉 채널

■ 은닉 채널의 실제 예시

- 전송 제어 프로토콜(TCP; Transmission Control Protocol)은 인터넷 어디에나 있음
- 전송 제어 프로토콜의 헤더는 '예약된(reserved)' 필드를 가지고 있는데 이는 그 어떤 것에도 사용되고 있지 않는 미래의 쓸모를 위해 예약된 것
- TCP 순서 번호나 ACK 필드에서 정보를 숨겨 더 비밀스러운 은닉 채널을 만드는 것도 쉬움

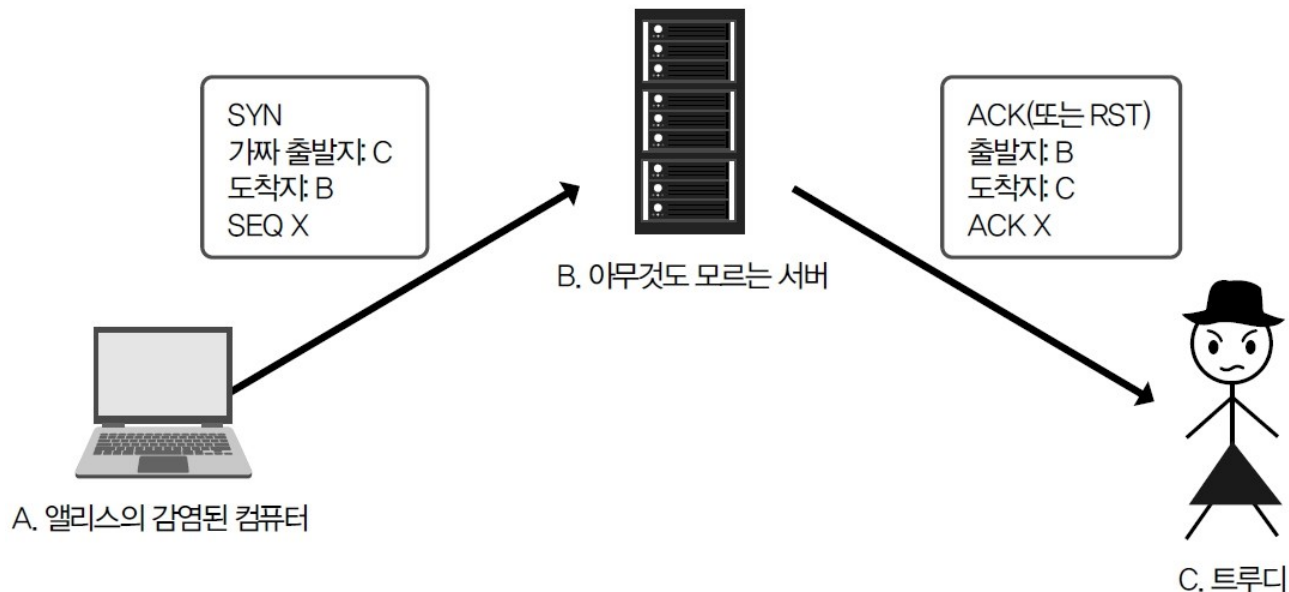


그림 7-6 TCP 순서 번호를 이용한 은닉 채널

7.6 추론 제어

■ 목적

- 누출이 발생하는 것을 막는 것이며 데이터에 대한 접근은 유지하면서 적어도 그런 누출을 최소화하는 것
- 추론 제어에서 사용하는 기법
 - 질의의 크기를 제어하는 것으로 질의의 결과가 너무 작으면 응답하지 않음
 - N -응답, $k\%$ 지배 규칙
 - 이에 따르면 N 또는 더 적은 주체에 의해 $k\%$ 이상의 결과가 나온다면 데이터가 공개되지 않음
 - 무작위화(데이터에 적은 양의 무작위 잡음을 넣는 것)

7.7 캡차

■ 튜링 테스트

- 컴퓨터 개척자이자 이니그마의 해독자인 앨런 튜링 Alan Turing이 1950년에 제안함
 - 이 테스트에서는 한 사람이 다른 사람과 컴퓨터에게 질문을 던짐
 - 질문자는 오직 키보드로만 질문을 던질 수 있고 응답도 컴퓨터 스크린에만 나타남
 - 질문자는 어느 쪽이 컴퓨터인지 사람인지 모르며 이 질문자의 목표는 오직 질문과 답변으로만 사람과 컴퓨터를 구별해내는 것
 - 만약 사람 질문자가 추측하는 것 이상의 확률로 이 퍼즐을 풀 수 없다면 컴퓨터는 튜링 테스트를 통과한 것 - 어떤 컴퓨터든 아직 튜링 테스트를 통과하지 못함

■ 캡차(CAPTCHA)

- 컴퓨터와 사람을 구별 짓는 완전히 자동화된 공개 튜링 테스트
 - 사람은 통과할 수 있지만 컴퓨터는 확률상 통과할 수 없음(역튜링 테스트)
- 캡차는 사람이 아닌 컴퓨터가 자원에 접근하는 것을 막기 위해 설계되었기 때문에 접근제어의 한 형태

7.7 캡차

- 초기 캡차는 종종 [그림 7-7]에서의 예시와 같이 왜곡된 문자의 형태로 나타남



그림 7-7 캡차 예시

- 캡차를 무력화하는 것은 인공지능AI 영역에서 어려운 문제로 간주됨
- 왜곡된 문자를 자동으로 인식하는 것과 잡음이 섞인 소리에서 제대로 된 발음을 자동으로 추출해내는 것 모두 AI가 풀어야 할 과제

7.8 요약

- 인가의 역사
- 램슨의 접근제어 목록과 권한 목록
- 대리 혼돈 문제
- 은닉 채널과 추론 제어
- 다단계 보안
 - 벨-라파둘라
 - 비바 모델
- 구획화
- 캡차

정보보안 이론과 실제

3판

암호, 접근제어, 네트워크 보안, 소프트웨어

감사합니다.